

Broken Access Control (BOLA/IDOR) Assessment Report

Definition

Broken Object Level Authorization (BOLA), also known as Insecure Direct Object Reference (IDOR), occurs when an application fails to verify whether an authenticated user is authorized to access a requested object. As a result, an attacker may gain unauthorized access to another user's data by simply modifying an object identifier such as a user ID, order ID, or address ID.

Objective

To assess whether the Address API is vulnerable to Broken Object Level Authorization (BOLA/IDOR) by attempting to access another user's address using a valid authenticated session.

Target Endpoint

GET /api/Addressss/{id}

Testing Methodology

1. Created two separate user accounts.
2. Created an address for each user.
3. Confirmed that each user could access only their own address.
4. Identified the Address IDs assigned to each user.
5. Logged in as User 1.
6. Modified only the Address ID in the request to reference User 2's address while keeping User 1's JWT unchanged.
7. Sent the modified request using Burp Suite Repeater.
8. Observed the application's response.

Original Request

GET /api/Addressss/7

Authorization: Bearer <User1 JWT>

Result: HTTP 200 OK

Modified Request

GET /api/Addressss/8

Authorization: Bearer <User1 JWT>

Result:

HTTP/1.1 400 Bad Request

```
{  
  "status": "error",  
  "data": "Malicious activity detected."  
}
```

Observation

The application did not return another user's address when the object identifier was modified. Instead, it detected the manipulation attempt and returned an error response indicating suspicious activity.

Conclusion

During testing, no Broken Object Level Authorization (BOLA/IDOR) vulnerability could be demonstrated for the GET /api/Addressss/{id} endpoint.

The application successfully prevented unauthorized access to another user's address and returned a security error instead of exposing sensitive information.

User 1 Accessing Own Address

[illegible]

User 2 Accessing Own Address

[illegible]

Unauthorized Access Attempt

[illegible]